

SOC/L1 -12.2. File and Hash Threat Intel

Task 1 - Introduction

This room simulates real-world scenarios where attackers disguise malicious files using misleading names and extensions, requiring defenders to investigate using hash lookups, sandboxing, and behavioral analysis. This room provides a step-by-step guide through the challenge, covering everything from identifying suspicious filenames to extracting SHA256 hashes and interpreting threat labels across platforms like VirusTotal, Hybrid Analysis, and MalwareBazaar.

- Detect suspicious file naming conventions and double extensions used for masquerading malware
- Extract and analyze file hashes using PowerShell and CMD on Windows systems
- Use VirusTotal and MalwareBazaar to classify threats and identify MITRE ATT&CK techniques
- Perform sandbox analysis with Hybrid Analysis to uncover stealthy behaviors and command executions
- Interpret threat labels, process trees, and dropped files to build a complete attack narrative
- Apply these techniques to real-world SOC workflows for faster detection and incident response

Task 2 - Filenames and Paths

Filepath Analysis: File paths and names are like crime scene clues, revealing attacker behaviour. Attackers may use different disk locations to hide their actions and reduce visibility.

C:\ (System drive) can be a common target for persistence mechanisms.

C:\Users\Public profile can enable cross-user access of detonated adversary tools.

C:\Users\Public\Public Downloads provides a high-traffic directory that would often evade strict monitoring.

Attackers are also known to modify filenames to escape detection through implementing various types of heuristic indicators, including:

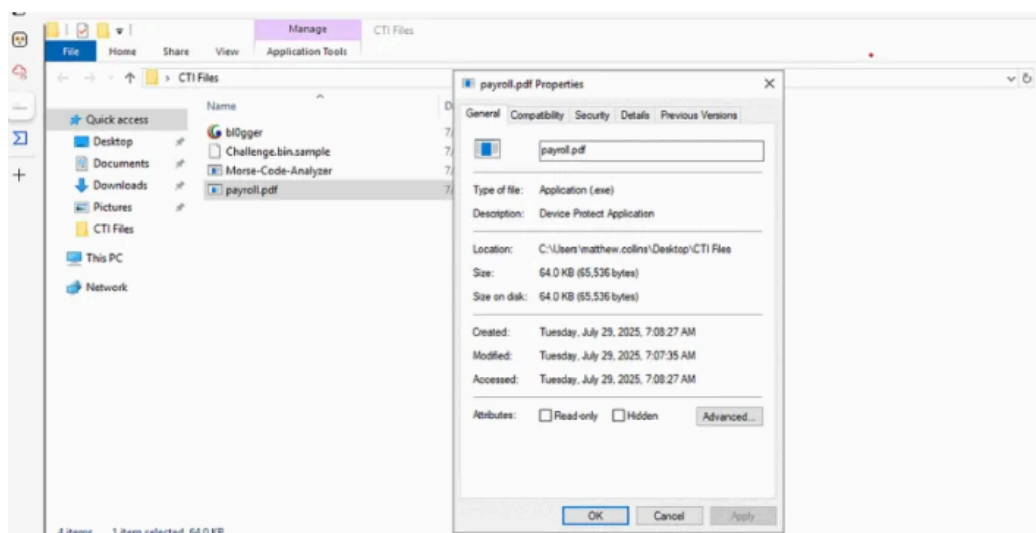
Double extensions - An example is invoice.pdf.exe, which leverages Windows' default settings that hide file extensions.

System binary impersonation - A filename such as scvhost.exe abuses the user's familiarity with core system processes. Defenders should include legitimate locations for system processes in an allowlist, rather than standalone filenames.

High-entropy Strings - A filename such as jh8F21.exe suggests automated packing or polymorphic generation, which is commonly used in a high-churn phishing operation.

Masquerading - Filenames such as backup-2300.exe can blend with routine files, thus leveraging on reduced suspicion. Another example is a single character substitution, which can bypass detection while looking visually legitimate to an unsuspecting employee.

One of the files included in the CTI Files folder on the Desktop shows one of the indicators mentioned. Can you identify the file and the indicator? payroll.pdf, Double extensions

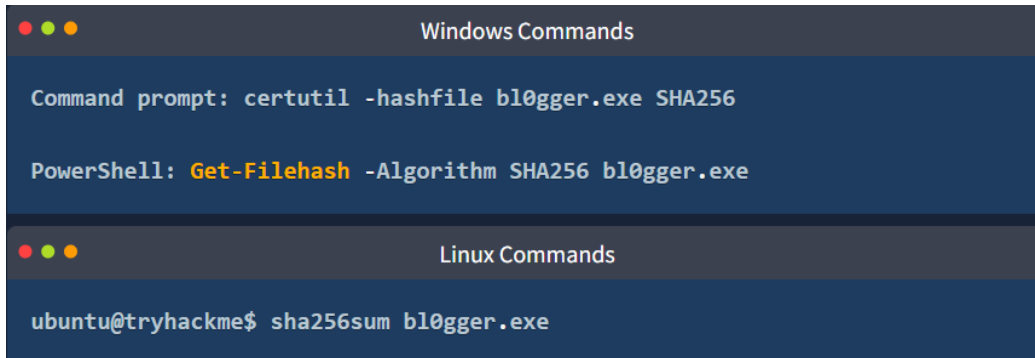


As we can see, the file is named with a double extension, and it is an executable.

Task 3 - File Hash Lookup

File hashes uniquely identify files and malware, regardless of name changes. Attackers constantly rename their malware; hashes provide an immutable, actionable way to identify it. It is advisable to work with potentially malicious binaries in a

separate, isolated environment. We can generate and verify our file hash using the following commands:



```
Windows Commands
Command prompt: certutil -hashfile bl0gger.exe SHA256
PowerShell: Get-Filehash -Algorithm SHA256 bl0gger.exe

Linux Commands
ubuntu@tryhackme$ sha256sum bl0gger.exe
```

A few pointers as analysts when dealing with hashes:

- Store the hashes in lowercase to avoid needless differences.
- Hash what matters in your investigation. For example, if the malware resides in a ZIP file, hash both the archive and the extracted binary.
- Do not leave plain strings without the context of where and when you encountered them.
- Any byte change will change the resulting hash.

Analysis With VirusTotal: It is a widely used threat intelligence service that aggregates scan results from dozens of antivirus vendors into a single report. There are several items from the search results that would be worth taking note of when you submit a hash:

Detection score: This represents a crowdsourced security verdict from various vendors displayed as a ratio. The higher the number, the higher the confidence threat.

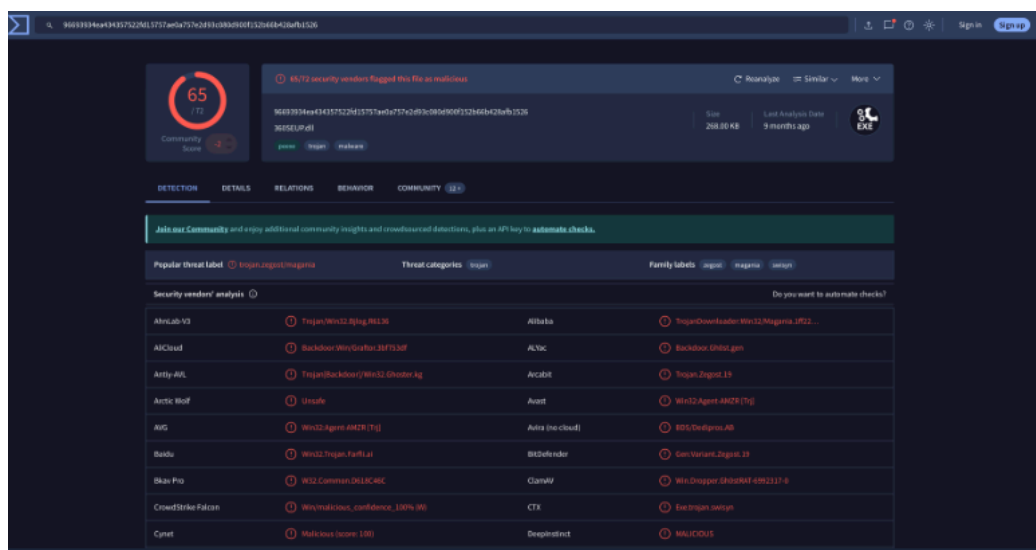
Threat labels and categories: These are vendor-specific classifications of threats that help confirm their attribution across vendors.

Detection rules: These are the technical signatures used by AV engines to identify threats. Typical classifications are YARA rules, Heuristic patterns, and behavioural triggers.

Properties: This is where the core metadata for the file is stored, including the file type, size, and compilation timestamp.

Contained domains and IPs: This information covers the malware's network infrastructure.

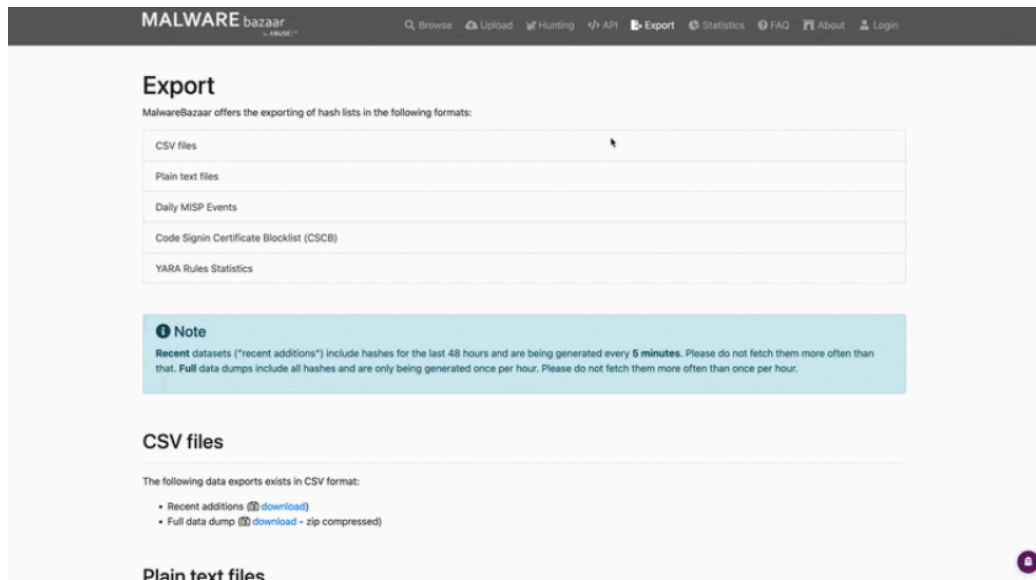
Contained files: This section details any files embedded or dropped during the malware's execution.



Cross-Reference With MalwareBazaar: [MalwareBazaar](#) (opens in new tab) is an all-in-one database for malware collection and analysis. The project supports the following features:

- **Malware Samples Upload:** Security analysts can upload their malware samples for analysis and build the intelligence database. This can be done through the browser or an API.
- **Malware Hunting:** Hunting for malware samples is possible through various elements, such as :
 - **Malware Family tagging:** You will find files classified by their malware families. An example of this is a file with only 5/70 detections on VirusTotal but tagged as #IcedID in MalwareBazaar; it should be treated as malicious.
 - **YARA rule integration:** Many submissions will include rules that detect related samples. As an analyst, you should take note of these rules to be added to the EDR/SIEM for future hunting.
 - **Campaign attribution:** Tags such as #TA551, which belong to a threat actor group, help link observed incidents to known adversaries. This can help identify coordinated attacks against an environment.

- **Sample Availability:** Malware samples are available for download and analysis. Reanalysing samples in a sandbox is best practice, which we shall cover in the next task.

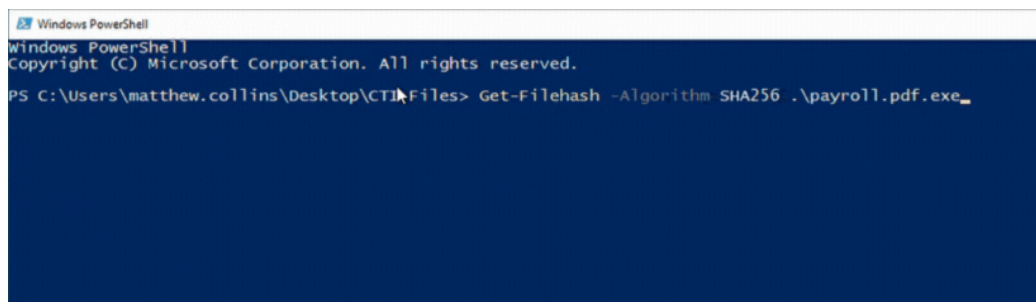


In a production environment, you would search MalwareBazaar using the syntax is `sha256:<file_hash>`. For our case, TryDetectThis has integrated the vendor intelligence from VirusTotal and MalwareBazaar.

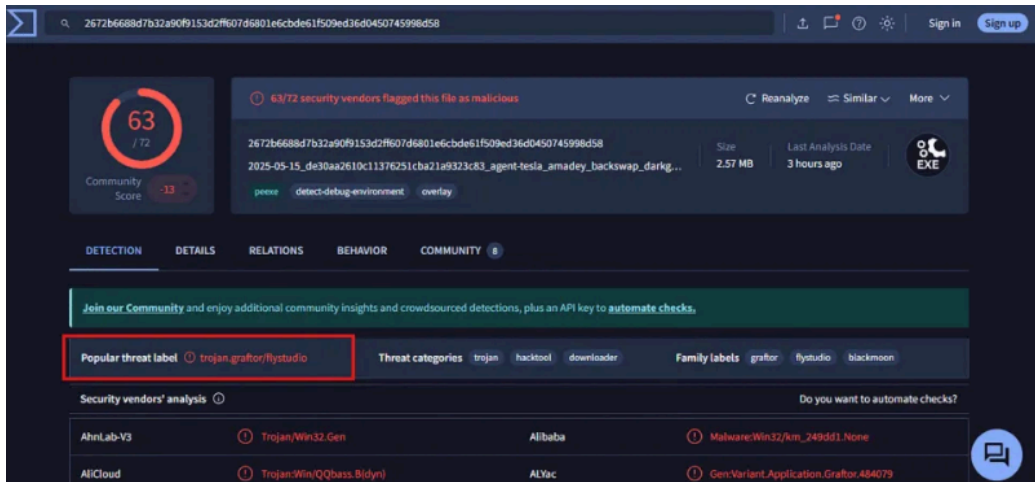
What is the SHA256 hash of the file bl0gger?

2672b6688d7b32a90f9153d2ff607d6801e6cbde61f509ed36d0450745998d58

We are working with a Windows machine. We have two options to get the hash: using CMD or PowerShell.



What is the threat classification label used to identify the malicious file?
trojan.graftor/flystudio

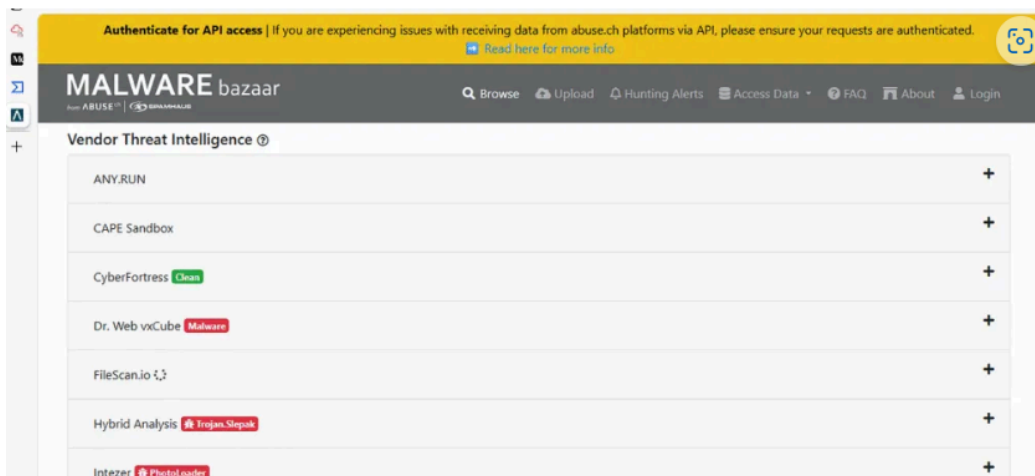


When was the file first submitted for analysis? 2025-05-15 12:03:49

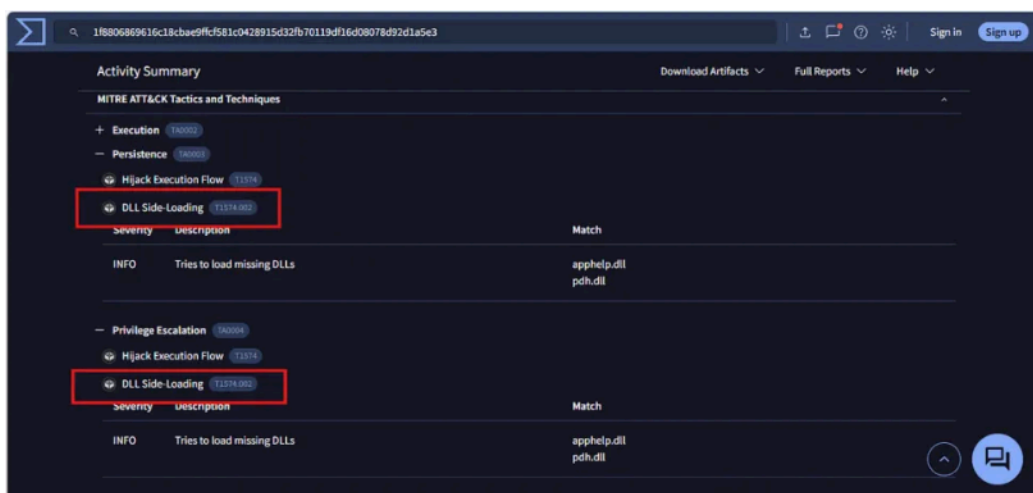
The first submission will appear under the "Details" tab. Currently, we are on the "Detection" tab.

Which vendor classified the Morse-Code-Analyzer file as non-malicious?
CyberFortress

Now get the hash of Morse Code Analyzer file in the same way as demonstrated in the GIF above. Put this way:
sha256:1f8806869616c18cbae9ffcf581c0428915d32fb70119df16d08078d92d1a5e3



What MITRE technique has been flagged for persistence and privilege escalation for the Morse-Code-Analyzer file? DLL Side-Loading



Task 4 - Sandbox Analysis

Dynamic Analysis for SOC: Static properties such as hashes, strings, and sections tell you identity. To understand the impact of malicious files, you need to execute them safely in a controlled environment. Sandboxes provide a disposable VM instrumented to capture every process, registry write, and network packet associated with the malware being investigated. Security analysts will use sandboxes to do three things:

Confirm execution - if nothing happens, your alert might be a decoy.

Extract runtime IOCs - domains, mutexes, dropped payloads, feed hunts and detections.

Map to ATT&CK - most sandboxes auto-label behaviour with technique IDs, fast-tracking your report.

As an L1 analyst, you would use the sandboxes' lookup features to quickly identify information about an obtained hash, while senior analysts would perform the other sophisticated tasks.

Sandboxing Tools

The most widely used tools for detonating wild malware are Hybrid Analysis(opens in new tab) and Joe Sandbox(opens in new tab), each with its distinct application:

Hybrid Analysis (HA) focuses on behaviour trees and a clean MITRE ATT&CK heatmap. It is suitable for a fast executive summary.

Joe Sandbox (JS): goes deep, covering system calls, strings, and memory dumps. Great for reverse engineers and detection engineers.

Analysing Hybrid Analysis Report

When we search using the file hash and analyse the generated report(opens in new tab) from Hybrid Analysis, we can confirm that the file is malicious, with a threat score of 100/100. Additionally, TryDetectThis has all the details ingested for the remainder of the room. We are also provided with information about the file's risk behaviour and the ATT&CK Techniques the threat actor observed using.

HYBRID ANALYSIS Sandbox Quick Scans File Collections Resources Request Info

2025-05-15_de30aa2610c11376251c8a21a9323c83_agent-tesla_amadey_backswap_darkgate_elex_icedid_...

This report is generated from a file or URL submitted to this web service on May 15th 2025 12:31:47 (UTC)
Guest System: Windows 10 x64, Professional, 1020 (Build 19H2)
Report generated by Falcon Sandbox (Hybrid Analysis)

Overview Sample unavailable Copy Sample Name/URL Downloads External Reports File Analyse Hash Not Seen Before

This similar samples Report Filter: Positive Request Report Deletion

Incident Response

Risk Assessment

- Spyware**: Found a string that may be used as part of an injection method
POIs data to a webserver
- Stealer/Phishing**: Sets a global windows hook to intercept mouse events
Tries to steal Mail credentials from registry
- Persistence**: Spawns a lot of processes
Writes data to a remote process
- Fingerprint**: Queries kernel debugger information
Queries process information
Queries sensitive IE security settings
Queries the internet cache settings (often used to hide footprints in index.dat or internet cache)
- Evasive**: Tries to steal Mail credentials from registry
- Network**: Marks file for deletion
Calls an API typically used to create a HTTP or FTP session
- Network Behavior**: Contacts 5 domains and 6 hosts [View all details](#)

MITRE ATT&CK™ Techniques Detection

This report has 310 indicators that were mapped to 130 attack techniques and 12 tactics [View all details](#)

Additionally, we can gather all file details and information to inform our threat intelligence report. These details are vital for threat reporting, both internally and externally, including file compositions, imports, processes called, and network connections.

HYBRID ANALYSIS Sandbox Quick Scans File Collections Resources Request Info

2025-05-15_de30aa2610c11376251c8a21a9323c83_agent-tesla_amadey_backswap_darkgate_elex_icedid_rhadamanthys_smoke-loader

File Details

Filename: 2025-05-15_de30aa2610c11376251c8a21a9323c83_agent-tesla_amadey_backswap_darkgate_elex_icedid_rhadamanthys_smoke-loader
Size: 2.64MB (2695978 bytes)
Type: [View](#) [Download](#)
Description: PE32 executable (GUI) Intel 80386, for MS Windows, 4 sections
Architecture: WINDOWS
SHA256: 2672b668d7b32a90f9153d2f607a680e5c8de6f509ed36d045045998d58
MD5: de30aa2610c11376251c8a21a9323c83
SHA1: efb9de1e8193390920c8bca746b841684e
mddeep: 245765f5WYDaiHm6CorjanyPQGdH0JONZejDuC+efmOcrwi3ENyegjJHLeQVhX6L0tHvgjdPQRw/D4mizA0dLrB5v1
imphash: 0a16a06c568e596d76b4843e67c12de
authenticash: ca99ae426d9c019ef930ee4823e00963f2727b7bf93319f095ac159b02b
Compiler/Packer: Microsoft visual C++ 5.0

Resources

- Language**: ENGLISH
- Icon**:

Visualization

Input File (PortEx):

Endpoint Preview

Instructions Count: 30
Actions: [Show Preview](#)

Additional Static Data

- Entrypoint**: 0x40cab0
- Entrypoint Section**: .text
- ImageBase**: 0x400000
- Subsystem**: Windows GUI
- Image File Characteristics**: RELOCS_STRIPPED, EXECUTABLE, IMAGE, LINE_NUMS_STRIPPED, LOCAL_SYMS_STRIPPED, 32BIT_MACHINE
- DLL Characteristics**: Major OS Version: 4, Minor OS Version: 0

Classification (TrID)

- 38.4% (AX) DirectShow filter
- 22.2% (OCX) Windows ActiveX control
- 10.9% (CPL) Windows Control Panel Item (generic)
- 6.2% (EXE) installShield setup
- 5.9% (EXE) Win32 Executable MS Visual C++ (generic)

Sandboxing Limitations: While sandboxing is a powerful tool for malware analysis, it has critical limitations that SOC analysts must account for when performing threat intelligence. Unquestioningly trusting sandbox results can lead to false negatives, missed detections, or incorrect conclusions. These limitations include, but are not limited to, the following:

1. Sandbox Evasion Techniques

Threat actors would design their payloads to detect and evade sandboxes, leading to false negatives. Some of the common evasion tactics used include:

Environment Awareness Checks: Malware checks for signs of virtualised/sandboxed environments

Anti-Debugging & Anti-Sandboxing Tricks: Malware conducts debugger detection and checks for unique hardware IDs.

2. Limited Execution Time & Coverage

Most sandboxes terminate analysis after 2-5 minutes, which means multi-stage malware may not fully execute. Additionally, time-delayed attacks will evade detection. As previously covered, this would mean cross-referencing other threat intelligence resources.

3. Encrypted & Obfuscated Traffic

Many sandboxes cannot decrypt SSL/TLS traffic, leading to blind spots. This may result in HTTPS C2 Traffic appearing with no payload visibility or the malware utilising DNS tunnelling to hide data in DNS queries.

4. Fileless & Living-off-the-Land (LotL) Malware

Some threats never touch disk, bypassing traditional sandbox analysis by employing PowerShell Attacks and WMI Persistence.

What tags are used to identify the bl0gger.exe malicious file on Hybrid Analysis?

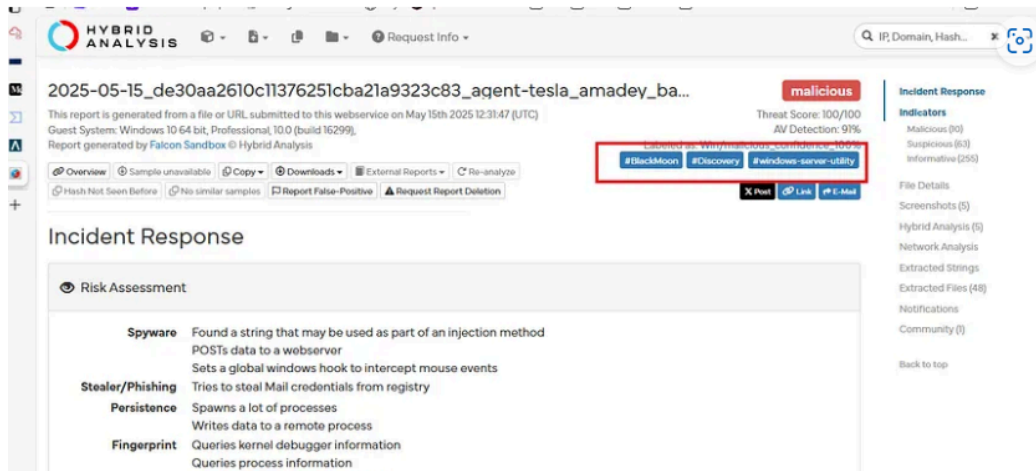
BlackMoon, Discovery, windows-server-utility

we need one more hash from file bl0gger.exe, use a similar method to get it. This time, the platform will be Hybrid-Analysis: Hash:

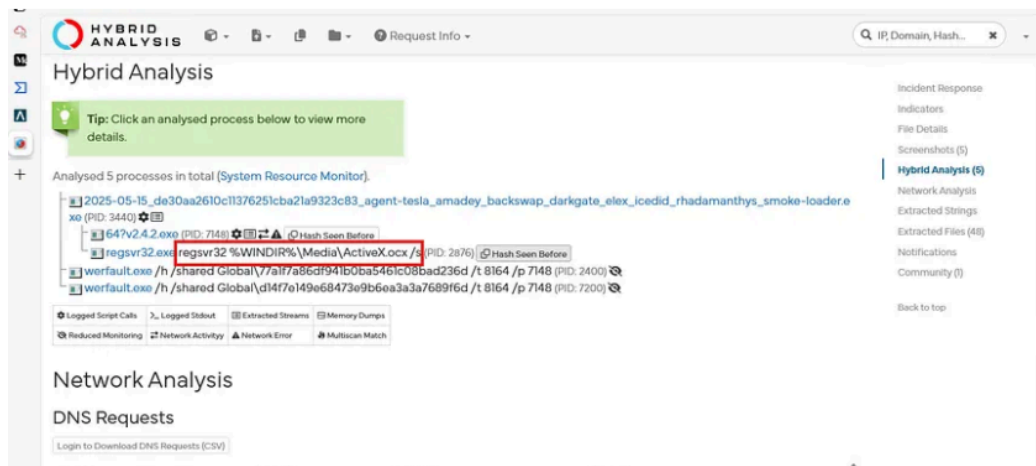
2672B6688D7B32A90F9153D2FF607D6801E6CBDE61F509ED36D0450745998D58

What was the stealth command line executed from the file?

regsvr32 %WINDIR%\Media\ActiveX.ocx /s



Which other process was spawned according to the process tree? werfault.exe



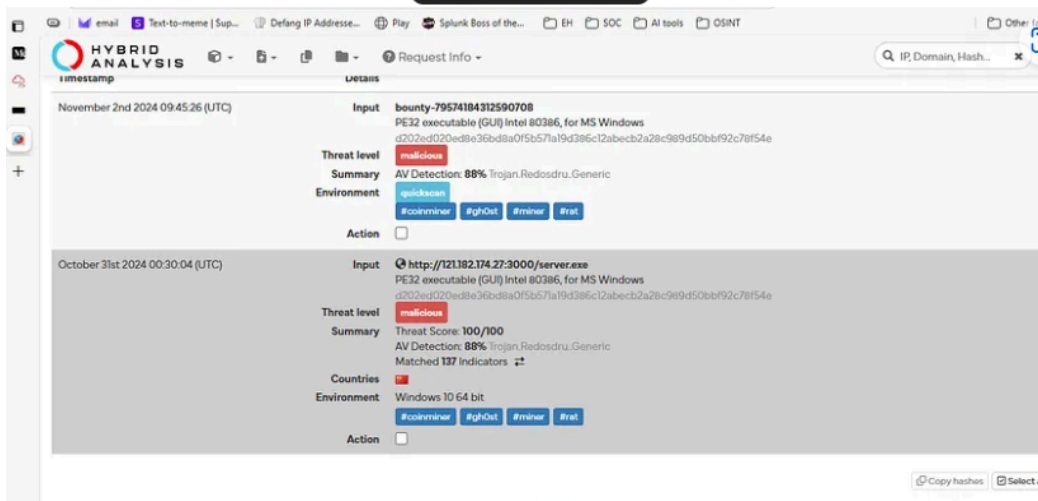
Analyze the payroll.pdf file located in the CTI Files folder and answer the questions below. The payroll.pdf application seems to be masquerading as which known Windows file?

svchost.dll

What associated URL is linked to the file? hxxp://121.182.174.27:3000/server.exe

Hash file:

D202ED020ED8E36BD8A0F5B571A19D386C12ABECB2A28C989D50BBF92C78F54E



How many extracted strings were identified from the sandbox analysis of the file?
454

Task 5 - Threat Intelligence Challenge

Practice: Now that we have looked at gathering threat intelligence through looking at file attributes, you will now have the opportunity to investigate a suspected file Challenge.bin.sample.

What is the SHA256 hash of the file?

43b0ac119ff957bb209d86ec206ea1ec3c51dd87bebf7b4a649c7e6c7f3756e7

What family labels are assigned to the file on VirusTotal? akira, filecryptor

Search the hash from Q1 on VirusTotal, Look for malware family classifications

Generate hash of the target file in the challenge, Use the file hash commands from Task 3

When was the first time the file was recorded in the wild? 2024-10-30 17:17:24 UTC

Name the text file dropped during the execution of the malicious file.

akira_readme.txt

Search hash on Hybrid Analysis or VirusTotal, Look in behavior analysis for dropped files

What PowerShell command is observed to be executed?

Get-WmiObject Win32_Shadowcopy | Remove-WmiObject

Check behavior analysis on sandbox platforms, Look for PowerShell command execution

What MITRE ATT&CK ID is associated with the actions of the command? T1490

The PowerShell command from Q5 relates to inhibiting system recovery, Look up the MITRE technique for this behavior. T1490 - Inhibit System Recovery, used by ransomware to prevent victims from restoring their files.

Task 6 - Conclusion

- Validate evidence before analysis: confirm you have the exact binaries and hashes.
- Analyse filepaths and filenames for quick context: Unusual storage locations, trusted software directories, and naming tricks highlight items that warrant deeper review.
- Generate hashes early to pivot into external or internal knowledge bases.
- Observe runtime behaviour in a controlled environment to confirm intent, extract network and persistence indicators, and map activity to recognised attack techniques.
- Translate findings into a brief that lists indicators by type, summarises behaviour and provides proportionate recommendations supported by evidence.